

1/48

File No.: EXP202311801

RESOLUTION OF TERMINATION OF THE PROCEDURE FOR RECOGNITION OF RESPONSIBILITY AND VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On March 30, 2025, the Presidency of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against ULPIA TRAJANA ALAMEDA S.L. (hereinafter, ULPIA), through the agreement that is transcribed:

<<

File No.: EXP202311801

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On July 4, 2023, a complaint was filed with the Spanish Agency for Data Protection for a possible infringement attributable to ULPIA TRAJANA ALAMEDA S.L. with NIF B90468273 (hereinafter, ULPIA).

The facts brought to the attention of this authority were:

The complainant states that they reserved a tourist apartment through the platform ***PLATFORM.1, and that the owner required the use of the application ***APPLICATION.1 to carry out the online check-in process.

They state that the aforementioned application requires photographing both sides of the ID card, as well as a photograph of the document holder to complete the check-in and reserve an apartment.

They claim that they contacted the respondent on June 21, 2023, via email requesting justification regarding this matter, but did not receive a response.

Along with the written complaint, the following was submitted:

- A copy of the email sent by the complainant to ***EMAIL.1 dated June 21, 2023, with the following content:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

2/48

"I have reserved an apartment through the platform ***PLATFORM.1 and I am required to check in on your platform ***APPLICATION.1. Upon checking in, I found that the data requested is excessive, violating Article 5.1.c) of the GDPR, the principle of data minimization. I understand that for legal reasons, the front side of the ID card is requested to verify the number and communicate it to the authorities if necessary, as indicated in your data protection policy. However, the information on the back of the ID card, which has been demanded for check-in to access the apartment I have reserved and already paid for, is not necessary. Furthermore, it also violates the principle of data minimization to require a photograph of my face. Both the image of my face and the back of the ID card are mandatory to complete the check-in. According to current regulations, this data is not necessary to communicate to the competent authority if there were any issues. According to current regulations, the data to be communicated would only be the ID card number, date of issue, nationality, date of birth, and date of accommodation delivery. On the other hand, the purpose of your policy states: "The personal data included in the web contact form by contacts and applicants will be processed in order to attend to your request and send you information about our products and services ***APPLICATION.1 related to accommodation." In this case, I have not been able to withhold my consent to not receive products and services from ***APPLICATION.1. I would like a response regarding why I am required to provide excessive data and how to eliminate that mandatory consent that I have not been able to cancel."

- A screenshot of the application ***APPLICATION.1 where it requests the "front" and "back" copy of

the identity document, as well as “facial identification.”

Additionally, the file includes:

- A screenshot of the privacy policy of ***APPLICATION.1, dated September 4, 2023, detailing information related to data protection:

“[...] the owner of this website is ***COMPANY.1 with CIF ***NIF.1, who can be contacted at the following address:

(...)

(...)

Phone: ***PHONE

Email address: ***EMAIL.1

PURPOSES BASED ON CONTRACTUAL RELATIONSHIP:

- The personal data included in the web contact form by contacts and applicants will be processed in order to attend to your request and send you information about our products and services

***APPLICATION.1 related to accommodation.

PURPOSES BASED ON LEGITIMATE INTEREST:

- To send you information about similar products or services marketed by ***APPLICATION.1 in relation to solutions applied to accommodation services.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

3/48

Regarding all the stated purposes, all requested data is mandatory; if not provided, ***APPLICATION.1 does not guarantee that the services rendered will fully meet your needs.”

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), this complaint was forwarded to ***COMPANY.1, for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

THIRD: On October 4, 2023, in accordance with Article 65 of the LOPDGDD, the complaint was admitted for processing.

FOURTH: On October 5, 2023, a response letter from ***COMPANY.1 was received by this Agency indicating:

“***COMPANY.1 acts as a data processor in the check-in processes of tourist accommodations on behalf of the data controllers, the owners of the accommodations, and has always attempted to reconcile the privacy of guests with the legal obligation established by Article 25 of Law 4/2015 on documentary registration and communication to the Security Forces and Corps of daily entry reports of accommodated clients.

[...]

The initial risk analysis was conducted on March 5, 2019, determining that the risks were acceptable concerning the following security measures: passwords, antivirus, disk encryption, backups hosted on ***PLATFORM.2. It was recommended to review the permissions of the developers and check the security guarantees of other providers outside of ***PLATFORM.2.

The most significant provider regarding the check-in process in the ***APPLICATION.1 app is ***COMPANY.2, which allows for the verification of the validity of the identity documents provided by the accommodated clients, the reading of the necessary data to fill out the entry reports of travelers, as well as the biometric authentication of the same, verifying through a photo from their smartphones that the person registering is the same as the one providing the identity document.

[...]

Regarding the principle of data minimization, the possibility of not only taking a still photograph of the guest to compare it with the identity document but also requesting a “proof of life” by asking the guest to move or make gestures to see that the person was indeed real and alive, and not attempting to pass off a copied and outdated still photo, was rejected. This option was discarded as it was considered too invasive of privacy.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeaeppd.gob.es

4/48

FIFTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGGD.

As a result of the actions taken, the following points have been noted:

The complainant submitted, along with their complaint, a document, a copy of the email sent by the complainant to ***EMAIL.1 on June 21, 2023, in which they request information on why so much data is required to check in.

They also request information on how to withdraw consent to not receive products and services from ***APPLICATION.1.

In the screenshot of the ***APPLICATION.1 app sent by the complainant, the following information is specified: "Check in by validating your identity and documentation," and in the mobile image, there is a space to upload a photo of the front of the ID, another photo of the back, and finally, a selfie for facial identification.

The Privacy Policy of ***APPLICATION.1 was reviewed, included in the file as an Annex to the entry, where information related to data protection is detailed, and it is confirmed that the email address to which the complainant sent their request was correct.

"[...] the owner of this website is ***COMPANY.1, with CIF ***NIF.1, who can be contacted at the following address:

(...)

(...)

Phone: ***PHONE

Email address: ***EMAIL.1

PURPOSES BASED ON CONTRACTUAL RELATIONSHIP:

- The personal data included in the web contact form by contacts and applicants will be processed for the purpose of attending to their request and sending them information about our products and services related to accommodation from ***APPLICATION.1.

PURPOSES BASED ON LEGITIMATE INTEREST:

- To send you information about similar products or services marketed by ***APPLICATION.1 related to solutions applied to accommodation services.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeppd.gob.es

5/48

Regarding all the stated purposes, all requested data is mandatory; if not provided, ***APPLICATION.1 does not guarantee that the services rendered will fully meet your needs."

Consulted on March 21, 2024, the information available on the website of ***APPLICATION.1 (...) shows that the previous information has been slightly modified, removing the purposes based on legitimate interest:

In the Privacy Policy (...) :

PURPOSES BASED ON PRE-CONTRACTUAL/CONTRACTUAL RELATIONSHIP:

- The personal data you provide will be processed by ***COMPANY.1 as the responsible party for this website ***URL.1 for the purpose of addressing your inquiry and contacting you, whether you are a potential client, employee, or supplier.

Regarding all the stated purposes, all requested data is mandatory; if not provided, ***APPLICATION.1

does not guarantee that we can address your inquiry.

The user of the ***APPLICATION.1 website will be solely responsible for the truthfulness and accuracy of the data provided, acting in good faith as a mere service provider. In the event that false data or data of third parties has been provided without their consent, ***APPLICATION.1 reserves the right to immediately destroy the aforementioned data in order to protect the rights of the owner or owners thereof.”

In the Legal Notice (...) :

“Purpose of the website: to inform about our activity, contact, consult, and provide remote access services, check-in, and app for guests. This document aims to establish the general terms and conditions of use of the PORTAL, which are mandatory for acceptance and compliance by all individuals, professionals, and companies (hereinafter the USER) who wish to use these (current or new services that ***APPLICATION.1 may provide in the future through the PORTAL).”

It is also interesting to highlight the features of the system offered on the page (...) :

“Highlighted Features of Our Online Check-In System

- Self check-in with identity documents and passports

- Validation of the authenticity of documents

- Biometric facial recognition

- Traveler's signature

- Generation of files with check-in reports

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

6/48

- Automatic uploading of reports to: National Police, Civil Guard, Mossos de Escudra, and Ertzaintza

- Obtains the personal email of all guests

- Ensures that all guests check in correctly and thus comply with regulations”

On November 20, 2024, the ***APPLICATION.1 APP is downloaded from the Apple Store, where the privacy policy of the APP can be viewed at the link:

(...)

“PURPOSES BASED ON CONTRACTUAL RELATIONSHIP

The personal reservation data of customers will be collected and processed by the Data Controller (owner of the apartment), for the purpose of providing accommodation services including online check-in, door opening, and information about the accommodation through the ***APPLICATION.1 application (Data Processor). You can consult the complete privacy information at the web link of the data controller.

PURPOSES BASED ON LEGAL OBLIGATIONS

The personal data of customers through the ***APPLICATION.1 application during the check-in phase will be processed to comply with various legal obligations and communicated to the Security Forces and Corps. This includes mandatory access to the camera functionality of the mobile device for identification and scanning of the Identity Document to comply with Organic Law 1/1992, of February 21, on the Protection of Citizen Security.

PURPOSES BASED ON LEGITIMATE INTEREST

Likewise, the ***APPLICATION.1 application includes providing guests with a destination guide and

commercial information about places of interest, leisure and cultural offerings in the area near their accommodation, as well as various plans and services. Each provider has its own privacy policy if you wish to request a service or make a purchase. Depending on the case, geolocation may be included to allow reaching the requested destination.

PURPOSES BASED ON CONSENT

Personal data will also be processed to geolocate you and keep you informed of the nearest points of interest to your geographical position (Consent granted via mobile phone). You can deactivate it through the settings of your mobile device.”

In its response to the transfer, ***COMPANY.1 provides the information already indicated in the previous section FOURTH and submits a copy of the ISO 27001 certification of the company

***COMPANY.2 as a guarantee of its subcontractor.

(...) certifies that the Information Security Management System of the organization:

***COMPANY.2

for the activities of:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepe.gov.es

7/48

Information security management system that supports the development, implementation, and support activities of the digital identity verification solutions of ***COMPANY.2, both in Software as a Service (SaaS) mode and in client installations (on premise), according to the Statement of Applicability dated 13/03/2023, is compliant with the requirements of the ISO/IEC 27001:2013 standard.

***COMPANY.1 explains that the incident of not responding to the request from the claimant was due to "an administrative management error regarding the emails received through the ***EMAIL.1 mailbox. Normally, the person directing a request or inquiry to us through this mailbox also indicates their identifying and contact information. However, in the case of the claimant, their email dated June 21, 2023, did not indicate this, except for their email address. And ***COMPANY.1 has been managing all those emails through a CRM tool that filtered them. We only saw that the communication was directed to us by A.A.A. and we mistakenly did not respond. We also erred in maintaining the purpose of commercial consent when this purpose was not active; consents are not collected in the app, nor has a commercial database been created, nor have any commercial communications been made, none."

Regarding the measures adopted to prevent similar incidents from occurring, ***COMPANY.1 indicates:

"To prevent similar incidents, we have replaced the email mailbox ***EMAIL.1 with ***EMAIL.2, without directing it through the CRM to ensure that all communications are answered in a timely manner.

[...]

We have updated the privacy policy of the ***APPLICATION.1 app on October 3, 2023, removing the purpose of commercial communications, changing the contact email address to ***EMAIL.2, and reinforcing transparency in indicating the necessity of verifying the identity document and the biometric authentication of the guest to comply with the obligation of accuracy under the citizen security protection law."

***COMPANY.1 provides a copy of the email sent to the claimant on September 20, 2023, from the address ***EMAIL.2, in which the above is explained and additionally highlights:

"And to be able to comply correctly with the three provisions (...). The photograph is collected to perform a biometric verification (see the legal report 0047/2021 from the Spanish Data Protection Agency regarding the difference between biometric data and biometric verification), and to verify that the person checking in and the one appearing on the ID are the same. Since it is a one-to-one verification, it is not considered a special category of data."

In the GUIDE ON PRESENCE CONTROL TREATMENTS THROUGH BIOMETRIC SYSTEMS issued by the AEPD in November 2023, in section IV. BIOMETRIC DATA AND SPECIAL CATEGORIES OF DATA, it specifies:

“The Guidelines 05/2022 from the European Data Protection Board (EDPB), on the use of facial recognition in the field of law enforcement (see Version 2.0, dated April 26, 2023), determine, in their section 12, that the concept of biometric data encompasses both ‘authentication’ and ‘identification’, and although they are distinct concepts, in both procedures data aimed at identifying a natural person are processed, so both are included in the concept of ‘data processing’, and more specifically, they are treatments of personal data of special categories. Consequently, the general prohibition established in Article 9.1 of the GDPR extends to both, so this prohibition must apply not only to treatments aimed at identification but also to cases of biometric data processing aimed at the authentication or verification of the person concerning the previously established pattern for them.”

***COMPANY.1 provides the document describing the check-in process in ***APPLICATION.1.

“At the moment a reservation is recorded on the ***APPLICATION.1 platform, it sends an automatic email to the guest with the download link for the app, the address of the accommodation, and their guest code.”

***COMPANY.1 sends a generic sample of the automatic email (not specific to the case of the claimant), where the obligation to use the ***APPLICATION.1 APP to check in, open doors, and access all information about the accommodation and the destination is verified. (see section 2.3.1) The document continues explaining:

“The Guest Code will allow you to: check in with your mobile to comply with traveler regulations, access the accommodation without the need for keys during your stay dates, and access information about the accommodation and the destination.

Reservation data can be automatically uploaded to the ***APPLICATION.1 system when made on platforms such as ***PLATFORM.1 or ***PLATFORM.2 if our client has a PMS management system and/or ***PLATFORM.3 with which we are integrated.

Reservations can also be created manually in our system by filling in the following data:

- Name
- Email
- Check-in date and time
- Check-out date and time
- Number of guests over 14 years old. (Obligation to complete traveler forms)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

9/48

Up to this moment, this is the only information we have about the client, which is provided by a PMS or manually filled out by the manager or owner of the accommodation.

[...]

The only way to access the app is by entering the personalized guest code and accepting the Terms and Conditions of the app.

[...]

A scan of the document is requested on both sides for the correct extraction of data, as the MRZ band is located on the back and for the validation of the document.

A facial scan is requested to match it with the photo on the document to prevent identity fraud.

The guest is shown the data extracted through the scanning process of their identity document. In case the system has not been able to read any data correctly, the guest is allowed to edit it manually through the form. In this case, the manager or owner of the accommodation receives an alert that there are unvalidated data automatically for them to check and validate manually.

A signature on the screen, an email, and acceptance of the Privacy Policy are requested to complete the registration.

[...]

The client is informed that the registration process has been successfully completed and is provided with the possibility to view the Traveler Report filled with their data and signature.

[...]

The manager or owner of the accommodation can view or modify, if necessary, the data of the guests. The files with the data of the travelers are sent daily and automatically to the State Security Forces, within the indicated period of a maximum of 24 hours from the guest's arrival.

The signed reports and the data of the travelers are stored for 3 years as mandated by the regulations.”

(Note: the underlining has been added by the Agency)

The information sent in the welcome email indicates the obligation to download the APP

***APPLICATION.1:

“It is necessary for you to download the app ***APPLICATION.1 before your stay to be able to check in, open the doors, and access all the information about the accommodation and the destination.

BASIC INFORMATION ON PERSONAL DATA PROTECTION AND CONFIDENTIALITY

The personal data you have provided directly or through the platform such as ***PLATFORM.2 or ***PLATFORM.1 is processed by the owner of the tourist accommodation Ulpia Trajana Alameda S.L., B90468273 Calle Martinez Montañés, 34, first floor, 41002 Sevilla, Sevilla, (...), as the data controller, to confirm your reservation, provide you with the accommodation service once check-in is completed through the provider's platform ***APPLICATION.1, and comply with legal obligations, especially the registration with the police once your identity has been verified through your image. You have the right to access, rectify, and delete the data, as well as other rights, as explained in the additional information. You can consult the detailed additional information on Data Protection on our website ***URL.1 or by directly contacting our organization via email at ***EMAIL.2 [...]

Upon requesting a copy or screenshot of the data associated with the claimant in ULPIA's systems, it provides the following information in its response:

“This party does not keep such information about any of its clients. Once provided by them, it is available for consultation through the ***COMPANY.1 application.

ULPIA TRAJANA ALAMEDA S.L. has a service acceptance agreement with the collaborating company, ***PLATFORM.1 (***PLATFORM.1 (...)) that is responsible for contracting telematically (via an APP) with the end client. This party is limited to informing ***COMPANY.1, S.L. about the contracting, which is responsible for processing the data of these clients, without this information or data, nor of course, personal documentation or facial images, being stored in any file of this party, as they are stored by said company once provided to the Police.

The client contracts directly with ***PLATFORM.1, through its website or its APP, to whom they pay, and these are responsible for billing with this party independently of the client's identity, only being relevant the number of days of stay, not the identity of the tenant. We do not need data from this client. Subsequently, the client registers in the APP of ***COMPANY.1, which provides them with the keys and instructions to access the accommodation. ***COMPANY.1 collects the essential data to comply with the duties before the police and facilitate the tenant access to the locks, which are their property. [...]

Therefore, all tenant data is not stored by ULPIA TRAJANA ALAMEDA S.L. In case of needing any access to them, caused by any legal obligation (this party does not need to access them for any other reason), it is done through the database of ***COMPANY.1.”

(Note: the underlining has been added by the Agency)

ULPIA provides the information of the claimant from the files of ***COMPANY.1 to comply with the request, as well as the contracts with ***COMPANY.1 and ***PLATFORM.1.

In the screenshot sent as evidence with the claimant's data, it is noted that the photographs of the ID cards and the selfie are not included. The specified data are as follows:

- ID Number: ***NIF.1

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

11/48

- Document type: (...)

- Date of issuance of the document: (...)

- First surname: (...)
- Second surname: (...)
- Name: A.A.A.
- Gender: (...)
- Date of birth: (...)
- Country of nationality: (...)
- Date of entry: (...)

The contract signed with ***COMPANY.1 on June 18, 2021 identifies ULPIA as CLIENT and ***COMPANY.1 as PROVIDER for the hiring of the APP ***APPLICATION.1 and refers to Regulation (EU) 2016/679 of April 27, 2016 (GDPR), to Law 15/1999, of December 13, on the Protection of Personal Data (LOPD1999), and to Royal Decree 1720/2007, of December 21, which approves the Development Regulation of Organic Law 15/1999 (RD1720) instead of referring to Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (LOPDGDD).

It indicates that ***COMPANY.1 acts as the data processor:

“In the event that the provision of the service requires access to personal data, the PROVIDER, as the data processor, is obliged to comply with” (LOPD1999) and (RD1720).

It includes a section 6 dedicated to the Protection of Personal Data where the instructions for the data processing assignment are specified.

“6.1. Object, nature, and purpose of the assignment:

The data processing will consist of fulfilling the object of this contract; the authorized processing operations will be strictly necessary to achieve the purpose of the assignment, including, if necessary, the collection, registration, structuring, modification, conservation, extraction, consultation, communication by transmission, dissemination, interconnection, comparison, limitation, deletion, and destruction of data, informing you that the obligations provided for in Title VIII of the RDLOPD for the BASIC security level must be applied.

6.2. Obligations and rights of the CLIENT

The CLIENT guarantees that the data provided to the PROVIDER has been obtained lawfully and that it is adequate, relevant, and limited to the purposes of the processing.

The CLIENT will make available to the PROVIDER any information necessary to execute the services subject to the assignment.

[...]

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeaepd.gob.es

12/48

The PROVIDER will not allocate, apply, or use the data to which it has access for a purpose other than the assignment or that implies a breach of this clause, without prior authorization.”

For its part, the adhesion contract with ***PLATFORM.1 provided is unsigned and indicates the Terms of Service for European Users, updated on January 25, 2024, which specifies “constitute a legally binding contract between ***PLATFORM.1 and you.”

“You also have the obligation to manage and use the personal data of Guests and other individuals in accordance with data protection legislation and these Terms, including the Privacy Standards for Hosts of ***PLATFORM.1.”

“28. Access to data.

Professional Hosts may access in their ***PLATFORM.1 account and in the Host panel the personal data and other types of data that have been provided by the Professional Host or their Guests, or that have been generated through the use of the ***PLATFORM.1 Platform, and that are necessary for the provision of their Hosting Services, as well as aggregated information about searches, bookings, and

the performance of their listings.”

When consulted about the origin of the personal data of the claimant and its method of obtaining, ULPIA responds in its reply that:

“That data, the name, and first surname, is provided to ***COMPANY.1 (which uses the trade name of ***APPLICATION.1) and this company generates a personal code that is provided to the customer” with a message informing about the check-in remotely.

ULPIA sends a screenshot of the welcome email sent to the claimant, which states:

“Hello A.A.A., welcome to your accommodation.

It is necessary for you to download the app ***APPLICATION.1 before your stay to be able to check-in, open the doors, and access all the information about the accommodation and the destination.

Watch this video before your stay to discover everything you can do with the ***APPLICATION.1 app: (...)

Download the app and enter this guest code.”

If this message is compared with the generic welcome email provided, it is noted that in the latter, the information about the YouTube video has been exchanged for the basic information about data protection specified earlier in this report (see section 2.3.1).

The YouTube video is an explanatory video about how to use the APP ***APPLICATION.1, with information similar to that provided in the document.

Additionally, in its reply, ULPIA indicates that the legal basis for the collection of such data is found in (LO 4/2015) and (RD 933/2021).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

13/48

Regarding the procedures followed to fulfill the duty of information and evidence of compliance, ULPIA refers to ***PLATAFORMA.1 and ***EMPRESA.1:

“As we mentioned earlier, on the company’s page that collects the data, with which the client contracts and where those data are registered, the procedure and required guarantees are outlined. On the other hand, ***EMPRESA.1 also complies with the obligation to provide information upon receiving the data, making the following message available to the tenant” and provides a copy of the information contained in the welcome email specified earlier in this report (see section 2.3.1).

Once again, the inspector wishes to highlight that the welcome email sent to the claimant contains a link to a YouTube video instead of information about data protection (where it refers to the email address ***EMAIL.2). Furthermore, the claimant registered with their mobile phone on June 21, 2023, and ***EMPRESA.1 informed in its allegations regarding the transfer of the complaint that, as a result of the complaint, it activated the email account ***EMAIL.2 and that they would cease using the CRM to address inquiries or exercise rights. The privacy policy of the app ***APLICACIÓN.1 was updated on October 3, 2023, changing the contact email address to ***EMAIL.2.

Notwithstanding the above, to access the app, it is necessary to enter the personalized guest code and accept the Terms and Conditions of the app.

Regarding retention periods, ULPIA indicates that they are not retained since the client pays ***PLATAFORMA.1 directly.

In its response, ULPIA continues to explain that the client contracts directly with ***PLATAFORMA.1, an entity that subsequently handles billing with ULPIA. The client then registers in the APP of ***EMPRESA.1, which provides them with the keys and instructions to access the accommodation, as the door has an electronic lock that opens with a code.

“At no time is there physical contact with the client, either by ULPIA TRAJANA ALAMEDA S.L. or by ***EMPRESA.1, so it is not possible to have in-person identification.

Since there is no physical contact with the client either by ULPIA TRAJANA ALAMEDA S.L. or by ***EMPRESA.1, the information must be provided online. Additionally, the provision of the ID card or other official documentation is mandatory,” in accordance with (LO 4/2015).

ULPIA provides the document [Resp_ULPIA#2_Doc#1], a contract signed with ***EMPRESA.1 on June 18, 2021, which has been analyzed in the previous point 3.1.1.

It also provides the document [Resp_ULPIA#3], Copy of the Registry of Personal Data Processing Activities, and insists that ULPIA “does not collect any personal data from its clients, and is limited to transmitting the information collected by ***PLATAFORMA.1 to ***EMPRESA.1, in such a way that none of the data provided by the client is processed or known by this party. Therefore, we refer to the information that ***PLATAFORMA.1 and ***EMPRESA.1 possess in this regard.”

The content of the RAT is reproduced:

Processing: Tenants

a) Data Controller

Identity: ULPIA TRAJANA ALAMEDA S.L. - NIF: B90468273

Postal Address: Calle Trajano, nº 45 - 41002 - Sevilla

Email: ***EMAIL.3

Phone: ***TELÉFONO.1

b) Purpose of Processing

Management of the relationship with tenants. Transfer of information from contracting pages to the access manager of the accommodation: ***EMPRESA.1

c) Categories of Data Subjects

Tenants: Individuals who stay in the accommodation.

d) Categories of Data

Identification: name, one surname, ID number, postal address, phone, email

e) Categories of Recipients

Security Forces and Bodies

Electronic lock company ***EMPRESA.1

f) International Transfers

No international transfers are planned

g) Retention Period

Data is not stored or recorded. It is retained by ***EMPRESA.1

h) Security Measures

As reflected in the ANNEX SECURITY MEASURES

Regarding the risk assessment, ULPIA again refers to the information that ***PLATAFORMA.1 and ***EMPRESA.1 possess in this regard and provides as its Risk Assessment, which consists of capturing the result of the AEPD Risk Assessment tool dated January 8, 2024, in which no risk factors have been specified.

Concerning the DPIA and technical reports from the DPO, ULPIA states that a DPIA is not needed and they do not have reports of recommendations, referring to those that ***PLATAFORMA.1 and ***EMPRESA.1 may have prepared:

“Due to the activity carried out and the procedure already explained regarding how personal data is processed, it is unlikely that this type of processing poses a high risk to the rights and freedoms of individuals.

Given the limited scope of the data provided, the small number of individuals involved (both the companies and, more importantly, the small number of tenants contracting with this company), and that they are only used to fulfill a legal duty of information to the Police, the risk to the rights and freedoms of individuals is minimal.

Therefore, in accordance with section 1 of Article 35 of the GDPR, an impact assessment of the processing operations on the protection of personal data is not necessary.

In any case, we refer to those held by the companies with which this party has processing contracts (***PLATAFORMA.1 and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

15/48

***COMPANY.1) on their behalf, due to their own characteristics, if they deemed such evaluation necessary.”

In their written response to the request, ***COMPANY.1 provides the following information and statements:

***COMPANY.1 indicates that the claimant registered with their mobile phone on 21/06/2023 at 11:49, at which point they accepted the privacy policy and the terms and conditions, and that on 29/06/2023, the date of entry to the accommodation, their data was reported to the National Police to comply with the Travelers Regulation.

The data that was recorded in the travelers' report and extracted through OCR reading of the MRZ band of their ID card are:

- ID Number: ***NIF.1
- Document Type:
- Document Issue Date: (...)
- First Surname: (...)
- Second Surname: (...)
- Name: A.A.A.
- Gender: (...)
- Date of Birth: (...)
- Country of Nationality: (...)
- Date of Entry: (...)

Regarding the origin of the data, ***COMPANY.1 indicates that “The origin of the reservation is a reservation created manually in the information system of ***APPLICATION.1 by the manager/owner of the accommodation, ULPIA TRAJANA ALAMEDA SL.” and sends as evidence a screenshot of the initial guest data to manage their reservation, which shows the following data:

- Name: A.A.A.
- Surnames: (blank)
- Email: ***EMAIL.3
- Check-in: (...)
- Check-out: (...)
- Adults >14: (...)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeaeapd.gob.es

16/48

- Children <14: (...)
- Language: (...)

***COMPANY.1 indicates that “The following email was sent from (...) with your guest code to the email address ***EMAIL.3”

The screenshot of the sent message is similar to that provided by ULPIA and analyzed in section 3.1.1. “Hello A.A.A., welcome to your accommodation.

It is necessary for you to download the app ***APPLICATION.1 [...]”

***COMPANY.1, in their written response to the request, provides the contracts with the entities ULPIA and ***COMPANY.2.

The contract with ULPIA is similar to the document provided by ULPIA and analyzed previously in point 3.1.1.

As for the contract of ***COMPANY.1 with ***COMPANY.2, it consists of a data processing agreement signed on March 1, 2020, in which ***COMPANY.1 acts as the Data Controller and ***COMPANY.2 acts as the Data Processor, for the provision of the service (...).

In relation to the Risk Analysis or Assessment, ***COMPANY.1 provides information about ***COMPANY.2:

“***COMPANY.2 has ISO 27001 certification, an international standard that establishes the

requirements for the implementation, maintenance, and continuous improvement of an Information Security Management System (ISMS). This system is used to protect the confidentiality, integrity, and availability of information. As part of the processes defined in this Information Security Management System, a comprehensive annual Risk Analysis is conducted from which Risk Treatment Plans and Continuous Improvement Plans are derived. The Risk Analysis and Management itself is carried out using the software tool ***TOOL.1 provided by the National Cryptologic Center (CCN) following the methodology (...)"

When requested for a copy of the Data Protection Impact Assessment in the context of customer registration, ***COMPANY.1 responds that this obligation corresponds to the Data Controller, ULPIA. ***COMPANY.1 as the Data Processor and ***COMPANY.2 as the Sub-Processor, we do not have an obligation to carry out an impact assessment related to this processing, although we do have an obligation to cooperate in its realization with the Data Controller.

However, we would like to point out that the complaint was made on July 4, 2023, that is, as we argued in the first written statement of allegations, under the old criterion of the Spanish Agency for Data Protection that distinguished biometric identification from biometric authentication or verification, for example, in report 0047/2021 or in the Labor Relations Guide published in 2021. In this

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

17/48

The guide indicates that only biometric identification treatments (One to many) require impact assessment. The Agency, following the Opinion of the European Data Protection Committee 5/2022, publishes its change of criteria in November 2023, so we understand that it is from that moment that the biometric verification included in ***APPLICATION.1 with the solution (...) from ***COMPANY.2 would fall under the obligation to carry out an Impact Assessment.

In light of the change of criteria regarding biometric data that must be considered specially protected data and the prohibition established in Article 9 of the GDPR, ***APPLICATION.1 has suspended the functionality of biometric verification in order to comply with the obligation of Article 4.3 of Royal Decree 933/2021 until the AEPD confirms that these treatments can continue to be carried out or a data controller provides us with a favorable impact assessment.

Subsequently, the European Regulation on Artificial Intelligence was approved in March 2024, which establishes an important exception as "AI systems intended for biometric verification, which includes authentication, whose sole purpose is to confirm that a specific natural person is the person they claim to be, as well as the identity of a natural person for the exclusive purpose of granting access to a service, unlocking a device, or securely accessing a location, are excluded."

That is to say, in our opinion, there is currently an apparent contradiction between the GDPR and the AI Regulation, as the latter considers biometric authentication treatments through AI, such as that of ***APPLICATION.1, via ***COMPANY.2, to be of low risk. We are awaiting whether the Spanish Data Protection Agency will modify its criteria regarding biometric authentication again and resolve this contradiction."

(Note: the underlining has been added by the Agency)

On November 23, 2024, it is verified that the option for Biometric Facial Recognition has disappeared from the information webpage of the auto check-in of ***APPLICATION.1 ((...)). A capture of this webpage is recorded as an associated object in the SIGRID system.

Regarding the processing of biometric data, ***COMPANY.1 indicates that the processing began on 06/21/2023 at 11:49, when the claimant registered with their mobile phone.

"Only at that moment was the processing of biometric data carried out, which lasts a few seconds. From the image of the ID and the selfie of the affected person, the app ***APPLICATION.1 through (...) generates a pattern from the two images and compares it automatically using AI. Once the biometric verification is completed, the process is validated for the person to continue with the check-in, and both

images are deleted.”

The responding party indicates that it has no control over the decision regarding the legitimizing bases, the duty of information, and other obligations directly enforceable against the Data Controller.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

18/48

Regarding the duty of information, it indicates the same text as the information contained in the welcome email specified earlier in this report (see section 2.3.1).

Requested evidence of compliance, ***COMPANY.1 states that, at the time of registration, the claiming party accepted.

Regarding the proportionality assessments of the processing carried out, ***COMPANY.1 indicates that it has no control over that decision in its role as data processor, but provides an extensive explanation about the solution (...) of ***COMPANY.2 which, among other topics, specifies.

“(…).”

“Finally, it should be noted that during the several years that the system has been operational, we have had to explain the system to the National Police during the course of some investigation related to a guest staying and a theft, for example, and we have always received a favorable opinion from them regarding the suitability, necessity, and proportionality of the check-in system of ***APPLICATION.1, which helps the Security Forces and Corps for the purpose of prevention, detection, and investigation of crime, especially in the prevention and investigation of terrorism-related crimes or those related to serious organized crime.”

***COMPANY.1 reiterates that, as a data processor, it has no control over the decision regarding which exceptions provided in Article 9 of the GDPR apply to the use made by the Data Controller. However, it refers to the fact that the events subject to the claim occurred at the end of June 2023 when the old criterion of the Spanish Agency for Data Protection regarding biometric data applied, which distinguished between identification and biometric authentication/verification, “leaving the latter outside the prohibition of Article 9 and finding its basis for legitimacy in compliance with legal obligations under Article 6.1.C.”

Retention periods for personal data.

The responding party indicates a retention period for the personal data subject to processing of 3 years and claims the application of the regulation (RD 933/2021) which in its Article 5 establishes:

“Article 5. Obligations for documentary registration.

1. The obligated subjects must maintain a computerized record containing the data listed in Annexes I and II, depending on the activity they carry out, including, where applicable, the data of persons under fourteen years of age.
2. The obligated subjects must register and retain those data of their users, included in Annexes I and II, that they collect in the exercise of their activity, under the terms determined.
3. The data in the computerized record must be retained for a period of three years from the completion of the contracted service or provision [...].”

It also indicates the following:

“1) Data Controller: ULPIA TRAJANA ALAMEDA SL

2) Data Processor: platform provider (***COMPANY.1. “***APPLICATION.1”)

3) Sub-Processor: remote identification technology provider (***COMPANY.2)

Regarding the claim and biometric verification, ***COMPANY.2 acts as a sub-processor of the data processing carrying out the following processing tasks assigned by the Data Processor,

***COMPANY.1, under the service provision contract:

- It performs an OCR reading of the necessary fields of the ID for the registration of guests, as provided in current regulations.
- Likewise, it performs a facial image comparison of the user, captured at the time of registration, with the image on the ID, using biometrics for this purpose.

Both operations are completely automated without the intervention of personnel from ***COMPANY.2 or access to personal data.”

Regarding the validation of the ID, in its response to the request, ***COMPANY.1 confirms that the only data extracted are those contained in the MRZ band, clarifying that the information extracted from the document is as indicated in the Order on registration books and entry reports of travelers in hospitality establishments and other similar ones (see section 3.2.1 of this report).

“Information is extracted in accordance with applicable regulations and is made available to the Data Controller through the ***APPLICATION.1 platform, being deleted at the end of the identity verification process.”

***COMPANY.1 specifies that the recognition of the data using OCR technology “is performed on a secure server under the control of ***COMPANY.2 located within the European Economic Area, with the data extraction taking place on that server.

The transmission of images between the mobile application ***APPLICATION.1 and the server is carried out through a secure channel that guarantees the confidentiality and integrity of the transmission, using current cryptographic protocols considered secure in the industry (TLS 1.2 or higher).”

Regarding the lifecycle of the photographs, ***COMPANY.1 confirms that all information is securely destroyed, including photographs of the identity document, as soon as the identity verification and registration process is completed.

The responding party describes the biometric authentication process in the following steps:

20/48

- 1) The image of the ID card is captured.
- 2) The image of the user (selfie) is captured.
- 3) Biometric algorithms are applied to compare the degree of match between the ID card image and the selfie.
- 4) A score is returned indicating the level of confidence that it is the same person.
- 5) No biometric pattern or similar is recorded, nor is any other type of biometric search or comparison performed. The images and data used in the biometric authentication are immediately and automatically deleted upon completion of the process.

Regarding storage, ***COMPANY.2 indicates that there is no storage: “All captured information is securely destroyed as soon as the user authentication process is completed. No type of minutiae or biometric pattern is recorded, limiting the processing to the comparison between the photo present in the document and the user's selfie. [...] In any case, the ***COMPANY.2 platform processes information securely, both that which is processed temporarily and that which may eventually be stored (in other clients and use cases), and as part of the lifecycle of this processing also includes secure deletion procedures. For this:

- (...)
- (...)
- (...)

Regarding other information deemed relevant, ***COMPANY.1 states: “We request legal security as service providers since, as we have demonstrated, the criteria for biometric verification has changed, initially considered outside the biometric identification of Article 9 of the GDPR, now included in that provision since November 2023, and it may have to change again due to the approval of the AI Regulation which considers it low risk.

FIFTH: According to the report obtained from the AXESOR tool, the entity ULPIA is a company established in 2019, with a share capital of €3,000.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGD), the Presidency of the Spanish Agency for Data

Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es

21/48

II

Procedure

Likewise, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

In accordance with Article 64 of the LOPDGDD, and taking into account the characteristics of the alleged infringement committed, a sanctioning procedure is initiated.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file of actions will be archived, in accordance with the provisions of Article 64 of the LOPDGDD.

If no allegations are made to this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

III

Preliminary Issues

Article 4.1) of the GDPR defines “personal data” as: “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.”

Article 4.2) of the GDPR defines “processing” as: “any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure, or destruction.”

In this case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, since ULPIA carries out, among other processes, the collection and storage of personal data of natural persons, such as: name and surname, phone number, address, email, ID card, or biometric data that are subject to technical processing for identification purposes.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es

22/48

On the other hand, Article 4.7) of the GDPR defines the “data controller” or “controller” as: “the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; if the law of the Union or of the Member States determines the purposes and means of the processing, the data controller or the specific criteria for its appointment may be established by the law of the Union or of the Member States.”

This figure should not be confused with that of the data processor defined in Article 4.8 of the GDPR as:

“the natural or legal person, public authority, service, or other body that processes personal data on behalf of the data controller.”

The Guidelines of the EDPB 07/2020 on the concepts of “data controller” and “data processor” indicate two fundamental conditions for being considered a data processor, which must be analyzed on a

case-by-case basis to conclude whether this figure exists:

“76. To be considered a data processor, it is necessary to meet two fundamental conditions:

a) to be an independent entity from the data controller; and

b) to process personal data on behalf of the controller.” (underlined by the AEPD)

It is important to emphasize, at this point, that the EDPB Guidelines 07/2020 highlight that the concepts of data controller and data processor are functional concepts, and it is necessary to establish them based on their specific activities in the analyzed case and not based on the formal designation that may appear in the contract:

“12. The concepts of ‘data controller’ and ‘data processor’ are functional concepts: their purpose is to assign responsibilities based on the actual role of each party. This implies that the legal status of ‘data controller’ or ‘data processor’ of the participants must be established in principle based on their specific activities in a given situation and not based on the formal designation of a participant as ‘data controller’ or ‘data processor’ (e.g., in a contract). This implies that the assignment of the role of controller or processor must normally derive from an analysis of the facts or circumstances of the case and, consequently, is not negotiable.”

Therefore, to determine who is the data controller in each case, it will be necessary to ask two questions according to the aforementioned Guidelines:

“20. (...) The data controller is the one who decides certain essential aspects of the processing of the data. The responsibility for processing can be established in the regulations or inferred from an analysis of the facts or circumstances of the case. It is necessary to focus on the specific processing activities in question and understand who carries them out.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

23/48

determines. To this end, the following questions must first be examined:

“Why is the processing taking place?” and “Who has decided that the processing should be carried out for a specific purpose?”

Having established the above and in relation to the facts subject to the claim, it should be noted that ULPIA signed a contract with ***COMPANY.1 on June 18, 2021, which identifies ULPIA as CLIENT and ***COMPANY.1 as PROVIDER for the hiring of the APP ***APPLICATION.1, indicating that ***COMPANY.1 acts as the data processor:

“In the event that the provision of the service requires access to personal data, the PROVIDER, as the data processor, is obliged to comply with Law 15/1999, of December 13, on the Protection of Personal Data and Royal Decree 1720/2007, of December 21, which approves the Regulation for the development of Organic Law 15/1999 and other applicable regulations.” It includes a section 6 dedicated to the Protection of Personal Data where instructions for the data processing assignment are specified. “(...) The CLIENT will provide the PROVIDER with all necessary information to execute the services subject to the assignment. [...] The PROVIDER shall not allocate, apply, or use the data to which it has access for a purpose other than the assignment or that implies a breach of this clause, without prior authorization.”

Furthermore, the privacy policy provided by ***COMPANY.1, as the provider of the APP platform ***APPLICATION.1, states the following:

“PURPOSES BASED ON CONTRACTUAL RELATIONSHIP

The personal reservation data of customers will be collected and processed by the Data Controller (owner of the apartment), for the purpose of providing the accommodation service including online check-in, door opening, and information about the accommodation through the application

***APPLICATION.1 (Data Processor). You can consult the complete privacy information at the web link of the data controller.”

At this point, let us recall that the Guidelines 07/2020 on the concepts of “data controller” and “data

processor” in the GDPR of the EDPB determine the following:

“Joint Controllers

The figure of joint controllers may arise when there are several participants in the processing. The GDPR introduces specific provisions regarding joint controllers and establishes a regulatory framework for the relationship between them. The general criterion for the existence of joint responsibility in processing is the joint participation of two or more entities in determining the purposes and means of a processing operation. Joint participation may take the form of a common decision made by two or more entities or be the result of the convergence of decisions of two or more entities, provided that such decisions are...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

24/48

complement each other and are necessary for the treatment to be carried out, as they have a tangible effect on the determination of the purposes and means of the treatment. An important criterion for determining the existence of joint responsibility is the impossibility of the treatment without the participation of both parties, in the sense that the treatments by the different parties are inseparable from one another due to being indissolubly linked. Joint participation must involve the determination of the purposes, on one hand, and the means, on the other.

...

The term jointly must be interpreted in the sense of "together with others" or "not only" and can take various forms and combinations....

53. On the other hand, not all treatment operations in which several entities participate give rise to a situation of joint responsibility. The general criterion for the existence of joint responsibility for the treatment is the joint participation of two or more entities in the determination of the purposes and means of the treatment. Specifically, joint participation must involve the determination of the purposes, on one hand, and the means, on the other. If each of these elements is determined by all the entities in question, they must be considered jointly responsible for the treatment in question.

54. Joint participation in the determination of the purposes and means implies that more than one entity decisively influences the decision to carry out the treatment and the manner of doing so. In practice, joint participation can take various forms. For example, it may take the form of a common decision made by two or more entities or be the result of the convergence of decisions from two or more entities regarding the essential purposes and means.

55. Joint participation through a common decision implies deciding together and entails a common intention, and represents the most common interpretation of the term jointly included in Article 26 of the GDPR. Joint participation as a result of the convergence of decisions can be more specifically derived from the jurisprudence of the CJEU regarding the concept of "joint controllers of the processing." Decisions can be considered to converge in the purposes and means if they complement each other and are necessary for the treatment to take place in such a way that they have a tangible effect on the determination of the purposes and means of the treatment. It is important to note that the notion of convergence of decisions must be considered in relation to the purposes and means of the treatment, regardless of other aspects of the commercial relationship between the parties.

Consequently, to identify the convergence of decisions in this context, it is important to ask whether the treatment would not have been possible without the participation of both parties in the purposes and means, in the sense that the treatments by the different parties are inseparable from one another due to being indissolubly linked. However, the joint responsibility for the treatment as a consequence of the convergence of decisions must be distinguished from the figure of the processor.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

25/48

treatment, since this, despite participating in the treatment, does not process the data for its own purposes, but rather carries out the processing on behalf of the controller. (...)

59. There is joint responsibility for processing when the entities participating in the same processing carry it out for jointly defined purposes. This is the case when the participating entities process the data for the same purpose or for a common purpose.

60. Furthermore, in light of the case law of the CJEU, it is possible to determine joint responsibility when the participants pursue closely linked or complementary purposes, even if they do not share the same purpose in the processing.

In this regard, a broad concept of the data controller must be adopted, as a contrary interpretation would create a risk of evasion of the rules regarding the protection of personal data, since its aim is to ensure effective and complete protection of the data subjects, as established by the CJEU judgment of May 13, 2014, in case C-131/12, in paragraph 34.

The CJEU judgment of December 5, 2023, in case C-683/21, delineates when we are faced with joint controllers of processing:

“41 As the Court of Justice has stated, in order to be considered a joint controller of processing, a natural or legal person must therefore independently meet the definition of ‘controller’ as set out in Article 4, point 7, of the GDPR (see, in this regard, the judgment of July 29, 2019, Fashion ID, C 40/17, EU:C:2019:629, paragraph 74). (...)

43 As the Advocate General noted in paragraph 38 of his conclusions, participation in determining the purposes and means of processing can take various forms and result from a common decision made by two or more entities or from converging decisions of those entities. In the latter case, such decisions must complement each other, so that each of them has a concrete effect on the determination of the purposes and means of processing.”

The CJEU judgment of January 11, 2024, in case C-231/22, indicates regarding the existence of joint responsibility that:

“48 Furthermore, the Court of Justice has stated, on the one hand, that it is sufficient for a person to influence, for their own purposes, the processing of personal data and thereby participate in determining the purposes and means of that processing to be considered a joint controller of the processing and, on the other hand, that the joint responsibility of several agents for the same processing does not presuppose that each of them has access to the personal data in question (see, in this regard, the judgment of December 5, 2023, Nacionalinis visuomenės sveikatos centras, C 683/21, EU:C:2023:949, paragraphs 40 to 43 and cited case law).”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

26/48

In accordance with the CJEU ruling of March 7, 2024 (C-604/22), it is declared that even in cases of joint responsibility, there would be liability for processing by all controllers, although not necessarily equivalent regarding the same processing operation:

“58. In this regard, while each joint controller must independently respond to the definition of ‘controller’ in Article 4, point 7, of the GDPR, the existence of joint liability does not necessarily imply that, with respect to the same processing of personal data, the various parties have equivalent responsibility. On the contrary, the parties may be involved in different stages of the processing and to different degrees, so that the level of responsibility of each of them must be assessed taking into account all relevant circumstances of the specific case. Furthermore, the joint liability of several parties regarding the same processing under this provision does not presuppose that each of them has access to the personal data in question (see, by analogy, the judgment of July 10, 2018, Jehovan todistajat, C 25/17, EU:C:2018:551, paragraphs 66 and 69 and cited case law).

59. Participation in determining the purposes and means of processing may take various forms and result from a common decision made by two or more entities or from converging decisions of those entities. In the latter case, such decisions must complement each other, so that each of them has a concrete effect on the determination of the purposes and means of processing. Conversely, it cannot

be required that there is a formal agreement between those controllers regarding the purposes and means of processing (judgment of December 5, 2023, Nacionalinis visuomenės sveikatos centras, C-683/21, EU:C:2023:949, paragraphs 43 and 44) (...)"

In light of the above and considering the facts subject to the claim, in this case, we are faced with two entities, ULPIA and ***EMPRESA.1, which act as joint controllers of the personal data processing carried out through the application ***APLICACIÓN.1. As far as this procedure is concerned, this processing affects personal data contained in the ID cards of ULPIA's guests, as well as their biometric data for identification purposes.

Consequently, if it is confirmed during the investigation that the infringement alleged in this agreement occurred, ULPIA would be considered a joint controller, regardless of whether it has accessed the personal data provided by its guests during the check-in process.

IV

Obligation Breached. Data Minimization

Letter c) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

27/48

c) adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed ("data minimization");"

The objective of the aforementioned principle of data minimization, as derived from the jurisprudence of the Court of Justice of the European Union (cases C-708/18 and C-524/06), is to ensure that the processing of personal data is strictly limited to information that is adequate, relevant, and necessary to achieve legitimate and previously determined purposes. In this way, this principle seeks to prevent excessive or disproportionate use of data, thereby reducing the risks of unauthorized access, potential abuses, and violations of rights.

In the present case, the claimant, after reserving accommodation managed by ULPIA through a web platform, was required to download the ***APPLICATION.1 app and submit a photograph of their face and a scanned copy of their identity document on both sides through the app, for the purpose of check-in.

ULPIA signed a contract with ***COMPANY.1 on June 18, 2021, entrusting the check-in of guests to them through the ***APPLICATION.1 app.

The contractual relationship that entails the stay in accommodation justifies the processing of personal data of clients by ULPIA, as long as it is necessary for the fulfillment of the obligations arising from that stay; however, it does not justify access to all the information contained in the client's identity document, and even less so the request for a photograph or image of this document without a legal basis that justifies it.

ULPIA states in its response to the information request dated May 6, 2024, to this Agency that "Since there is no physical contact with the client either by ULPIA TRAJANA ALAMEDA S.L. or

***COMPANY.1, the information must be provided online. Furthermore, the provision of the ID card or other official documentation is mandatory, as it must be reported to the police, in accordance with Article 25 of Organic Law 4/2015, of March 30, on the protection of citizen security, in addition to Royal Decree 933/2021, of October 26, which establishes the obligations of documentary registration and information of individuals or legal entities engaged in hospitality and motor vehicle rental activities."

The regulations governing the registration books and entry reports of guests in hospitality establishments, as well as the obligation to communicate the information contained in the registration sheets to the State Security Forces and Corps, are primarily constituted by Organic Law 4/2015, of March 30, on the protection of citizen security (hereinafter, LO 4/2015), and Royal Decree 933/2021, of October 26, which establishes the obligations of documentary registration and information of individuals or legal entities engaged in hospitality and motor vehicle rental activities (hereinafter, RD

933/2021).

First, the activity carried out by ULPIA falls within the scope of application of this regulation, which is directed at individuals or legal entities that carry out

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

28/48

hospitality activities. For these purposes, Article 2 of RD 933/2021 establishes the following:

“Article 2. Definitions.

For the purposes established in this royal decree, the following are considered:

1. Hospitality activities: those carried out, whether professionally or not, with the aim of providing, in exchange for a price, consideration, or compensation, a room or space for overnight stay to individuals, with or without other complementary services. In any case, the following activities are included in this definition:

a) Those carried out by commercial establishments open to the public integrated into this sector in accordance with the regulations issued by the competent administration. This concept includes hotels, hostels, guesthouses, pensions, rural tourism establishments, or similar.

b) Those carried out by campsites and areas for parking motorhomes, regardless of their ownership or usage regime, apartments, bungalows, and other similar tourist accommodations.

c) Those of tour operators that provide intermediary services between companies dedicated to hospitality and consumers.

d) The activity of digital platforms dedicated, for a fee or free of charge, to the intermediation in these activities via the internet, whether or not they provide the underlying service subject to mediation, as long as they offer services in Spain.

2. Activities of renting motor vehicles without a driver: (...)

3. Obligated subjects: natural or legal persons who develop or mediate in the performance of the described activities.”

Article 24 of LO 4/2015 provides in its first section the following:

“Natural or legal persons who engage in activities relevant to public safety, such as hospitality activities (...) shall be subject to the obligations of documentary registration and information in the terms established by the applicable provisions.”

These obligations are currently established by the aforementioned RD 933/2021, to which the respondent refers, and whose Articles 4 and 5 provide the following:

Article 4. Entry reports in hospitality establishments and service sheets in vehicle rental activities.

1. The holders of hospitality and vehicle rental activities included within the scope of application of this regulation shall collect the data of the users of the same in order to proceed with their registration and the necessary communication for compliance with the legal obligations developed through this royal decree. (...)

3. The reports and sheets shall be provided by the hospitality or vehicle rental establishment, which shall be responsible for the accuracy of the data recorded therein, ensuring that they match the documents or systems that verify the identity of the individuals, which must be displayed or provided by the users of these services.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

29/48

Article 5. Obligations of documentary registration.

1. The obligated subjects must maintain a computerized record containing the data listed in Annexes I and II, depending on the activity they carry out, including, where applicable, the data of individuals under fourteen years of age.

2. The obligated subjects must register and retain those data of their users, included in Annexes I and II, that they collect in the exercise of their activity, in the terms determined.
3. The data from the computerized record must be retained for a period of three years from the completion of the contracted service or provision. (...)

On the other hand, it is Annex I. a), in its section 3 that establishes the data of guests whose collection is mandatory to incorporate into the so-called "Registration Sheet" that the entity responsible for the hotel must transfer to the State Security Forces and Corps, when it concerns professional hospitality establishments. Specifically, the following data of the traveler are legally required:

- "a) Name.
- b) First surname.
- c) Second surname.
- d) Gender.
- e) Identity document number.
- f) Document support number.
- g) Type of document (DNI, passport, TIE).
- h) Nationality.
- i) Date of birth.
- j) Place of habitual residence. – Full address. – Locality. – Country.
- k) Landline phone.
- l) Mobile phone.
- m) Email address.
- n) Number of guests.
- o) Relationship of kinship between the guests (in the case that any is a minor)."

Consequently, according to the provisions of this regulation, it is inferred that the obligation to collect and send the prescribed data corresponds to the obligated subject, that is, the hospitality service in this case, and that it is not mandatory to collect, register, or communicate to the competent authorities the image, photocopy, or complete image of the identity document of each traveler, but only some data contained therein such as: name and surnames, identification number, support number, type of document (DNI; passport, etc.), nationality, and date of birth. Therefore, it does not legitimize the processing of personal data consisting of collecting the complete copy of the document. And among this information that must be collected, even less is there a selfie for facial recognition. It must be taken into account that the image or photocopy of the traveler's DNI (on both sides), passport, or other documents verifying identity contains personal data that exceeds those required in this regulation, such as:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
30/48

the image or face of the traveler, the equipment number, or the names of the traveler's parents, for which there is no legal obligation for collection, registration, and communication, in accordance with the aforementioned regulations. All of these would be personal data whose processing involves excessive treatment that is contrary to the principle of data minimization provided for in Article 5.1.c) of the GDPR.

In this regard, the obligation to verify the accuracy of the data reflected in the identity document provided by the accommodated clients, as stipulated in Article 4.3 of Royal Decree 933/2021, can be achieved without the need to require and store the image of the identity document and the photograph of the faces of its clients, with ULPIA, as the data controller, needing to seek check-in alternatives that allow compliance with the aforementioned regulations.

Thus, the collection of the photograph of the client's identity document with all the information contained in that document and the request for a photograph of their person for the biometric authentication of the provided identity document could be understood, without prejudice to what results from the instruction, as processing of inadequate, irrelevant, and unnecessary personal data for the

specific purpose of processing, contrary to the principles of data protection, specifically, the principle of "data minimization," regulated in Article 5.1.c) of the GDPR.

Therefore, in accordance with the evidence currently available in this initiation agreement of the sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to ULPIA for violation of Article 5.1.c) of the GDPR.

V

Classification of the infringement of Article 5.1.c) of the GDPR and qualification for the purposes of prescription

Article 83.5 of the GDPR classifies as an administrative infringement the violation of the following articles, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9."

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purpose of the limitation period, Article 72.1 of the LOPDGDD establishes the following:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

31/48

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and will prescribe after three years, which constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

VI

Proposal for sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented in accordance with Articles 25 and 32;

e) any previous infringement committed by the controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular

whether the controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

32/48

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD provides:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The link between the infringer's activity and the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

In the present case, considering the severity of the possible infringement, especially regarding the consequences that its commission causes to the affected parties, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating what is established in Article 5.1.c) of the GDPR, allows for the initial setting of an administrative fine of 1,000.00 euros.

VII

Unfulfilled obligation. Processing of special categories of personal data

Article 9 of the GDPR, which regulates the processing of special categories of personal data, establishes the following:

"1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data aimed at identifying...

33/48

unambiguously to a natural person, data related to health or data related to the sexual life or sexual orientation of a natural person.

2. Paragraph 1 shall not apply when one of the following circumstances occurs:

a) the data subject has given explicit consent to the processing of such personal data for one or more of the specified purposes, except when Union law or the laws of the Member States provide that the

prohibition mentioned in paragraph 1 cannot be lifted by the data subject;

b) the processing is necessary for compliance with obligations and the exercise of specific rights of the data controller or the data subject in the field of labor law and social security and protection, to the extent that it is authorized by Union law or the laws of the Member States or a collective agreement under the laws of the Member States that establishes adequate safeguards for the respect of fundamental rights and the interests of the data subject;

c) the processing is necessary to protect vital interests of the data subject or another natural person, in the event that the data subject is not physically or legally able to give consent;

d) the processing is carried out, within the scope of its legitimate activities and with appropriate safeguards, by a foundation, an association, or any other non-profit organization whose purpose is political, philosophical, religious, or trade union, provided that the processing relates exclusively to current or former members of such organizations or to persons who maintain regular contact with them in relation to their purposes and provided that the personal data are not communicated outside of them without the consent of the data subjects;

e) the processing concerns personal data that the data subject has made manifestly public;

f) the processing is necessary for the formulation, exercise, or defense of claims or when courts act in the exercise of their judicial functions;

g) the processing is necessary for reasons of essential public interest, based on Union law or the laws of the Member States, which must be proportional to the objective pursued, respect the right to data protection in essence, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject;

h) the processing is necessary for purposes of preventive or occupational medicine, assessment of the worker's capacity, medical diagnosis, provision of health or social care assistance or treatment, or management of health and social care systems and services, based on Union law or the laws of the Member States or under a contract with a healthcare professional and without prejudice to the conditions and safeguards provided for in paragraph 3;

i) the processing is necessary for reasons of public interest in the field of public health, such as protection against serious cross-border threats to health, or

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

34/48

to ensure high levels of quality and safety in healthcare and in medicines or medical products, based on Union law or the laws of the Member States that establish adequate and specific measures to protect the rights and freedoms of the data subject, in particular professional secrecy;

j) the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes, in accordance with Article 89, paragraph 1, based on Union law or the laws of the Member States, which must be proportional to the objective pursued, essentially respect the right to data protection, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject.

3. The personal data referred to in paragraph 1 may be processed for the purposes mentioned in paragraph 2, letter h), when their processing is carried out by a professional subject to the obligation of professional secrecy, or under their responsibility, in accordance with Union law or the laws of the Member States or with the rules established by the competent national authorities, or by any other person also subject to the obligation of secrecy in accordance with Union law or the laws of the Member States or the rules established by the competent national authorities.

4. Member States may maintain or introduce additional conditions, including limitations, regarding the processing of genetic data, biometric data, or data related to health."

The GDPR defines in its Article 4.14 biometric data as personal data resulting from or produced by technical processing, according to its literal meaning "personal data obtained from a specific technical processing, relating to the physical, physiological, or behavioral characteristics of a natural person that allow or confirm the unique identification of that person, such as facial images or fingerprint data."

Biometric data are a type of personal data generated during the technical processing of biometric characteristics for the purposes of biometric recognition.

Thus, they are defined by their very purpose of allowing identification or confirming/verifying the same, with the addition in either case of being "unique to that person," in the case raised in the complaint that is the origin of this initiation of sanctioning procedure, based on two images, that of the ID card and a photo as in this case.

The term "biometry" derives from the Greek words "bio" (life) and "metrics" (measurement), reflecting its focus on the measurement and analysis of biological traits.

Biometric recognition is the automated recognition of individuals based on their biological and behavioral characteristics.

Unlike traditional forms of authentication, which are based on knowledge (for example, passwords) or possession (for example, identification cards), biometrics authenticates and identifies individuals based on who they are.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@epd.gob.es

35/48

son, taking advantage of unique physical or behavioral attributes. Biometric data are a type of personal data generated during the technical processing of biometric characteristics for the purposes of biometric recognition.

While traditional authentication methods such as passwords require a 100% match character by character to allow the user to access, for example, an account or application (deterministic methods), biometric methods are referred to as "probabilistic," because they are probabilistic technologies that can automatically recognize individuals by their face or fingerprint for authentication or identification (point 23 of Opinion 11/2024 on the use of facial recognition to streamline passenger flow in airports).

In both the biometric identification and authentication (verification) systems, the facial recognition techniques used are based on an estimated match between templates: the one being compared and the reference one that may have been previously registered. From this perspective, they are probabilistic techniques: the comparison deduces a greater or lesser probability that the person is indeed the one to be authenticated or identified; if this probability exceeds a certain threshold in the system, defined by its user or developer, the system will understand that there is a match.

The European Data Protection Board (EDPB) refers to this probability regarding the uncertainty of the result, which is not definitive as it is based on probabilities that two faces or images of faces correspond to the same person, as a "confidence score" (27 of Guidelines 5/2022 on the use of facial recognition in law enforcement).

A biometric system works with the biometric data obtained from a person, from which an algorithm selects features to create a biometric template. The system then checks the identity of the person against the biometric database. It can do this in a second while comparing hundreds of millions of biometric data in the database.

The definition is further narrowed by Recital 51 of the GDPR, relating to personal data that, "by their nature, are particularly sensitive in relation to fundamental rights and freedoms..." and specifically regarding photographs, such as those used by the respondent in the check-in process, stating: "Particular protection is warranted for personal data that, by their nature, are particularly sensitive in relation to fundamental rights and freedoms, as the context of their processing could entail significant risks to those rights and freedoms. (...). The processing of photographs should not be systematically considered as processing of special categories of personal data, as they are only included in the definition of biometric data when the fact that they are processed by specific technical means allows for the unequivocal identification or authentication of a natural person. Such personal data should not be processed unless their processing is permitted in specific situations provided for in this Regulation, given that Member States may establish specific provisions on data protection in order to adapt the

application of the rules of this Regulation.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
36/48

Regulation on compliance with a legal obligation or the performance of a mission carried out in the public interest or in the exercise of public powers conferred on the data controller. In addition to the specific requirements of that processing, the general principles and other rules of this Regulation must apply, especially regarding the conditions for the lawfulness of the processing. Exceptions to the general prohibition on the processing of these special categories of personal data must be explicitly established, among other things, when the data subject gives their explicit consent or in relation to specific needs, particularly when the processing is carried out within the framework of legitimate activities by certain associations or foundations whose objective is to enable the exercise of fundamental freedoms.

Biometric data processing systems are based on collecting and processing personal data related to the physical, physiological, or behavioral characteristics of individuals, including voice or facial characteristics through devices or sensors, creating biometric templates (also referred to as signatures or patterns) that enable the identification, tracking, or profiling of such individuals. It should be noted, on the other hand, that the identification process necessarily includes the performance of several processing operations (collection or capture of data, recording, storage, processing, comparison, authentication, retention, deletion, limitation, etc.).

During the phase of registering biometric data, the discriminative and identifying information contained in a face is extracted to be transformed into machine-readable biometric data. It is precisely this information that will allow for the individualization and identification of individuals.

A biometric template, or facial vector, is a form of writing of a human biometric characteristic, such as a face, a fingerprint, or a person's voice, in such a way that it can be efficiently and effectively interpreted by a machine for a specific purpose or purposes. The biometric template is not intended to be interpreted by a person, like a photograph, but is intended to be processed in an automated process, that is, to be efficiently and effectively interpretable by a machine. This registration, both through its storage and its real-time matching, can allow for the singularization of a person. The biometric template is the result of processing biometric data and contains the personal characteristics of the parameters captured from the user; it is a digital representation of the unique characteristics that have been extracted from a biometric sample and may or may not be stored in a database, on a card, or on the device itself (tablet, mobile).

Biometric data have the particularity of being produced by the body itself and definitively characterize it; they are not data about that person, but rather the data refer to the same person, their biometric identifiers are measures of inherently private information, which in principle cannot be modified by the will of the individual, nor can the person be released from them. Each facial structure of each person is unique to that person. Furthermore, because biometric data are unique to a person and perpetual, the user uses the same data across different systems.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeapd.gob.es
37/48

Therefore, they are unique, permanent over time, and the individual cannot free themselves from them; they can never be changed, not even with age, creating issues of liability in the event of compromise, loss, or intrusion into the system, posing a specific and significant risk to individuals. This means that if the biometric data is lost, stolen, or used inappropriately, unlike a PIN or password, it could not be changed or varied, granting access to all devices or accounts secured by that identifier. The immutability of biometric identifiers exposes individuals who use them to repeated cases of fraud.

Due to their special characteristics, it can be asserted that when compromised, this data has a more significant impact on the fundamental right to data protection of its holder compared to other types of personal data. Hence, the special relevance that must be given to the guarantees adopted in their processing due to the particularly significant impact on the fundamental right to the personal data protection of its holder.

Biometric data is a generic term that describes the different formats resulting from the transformation of biometric characteristics for measurement. The term encompasses the sample (untransformed) and the characteristics extracted from the sample or template (reduction of biometric characteristics into a mathematical pattern).

The term "biometric sample" refers to the capture of a sample from the individual extracted from that biometric characteristic (the face).

The registration of a person's biometric data in a database is referred to as a "biometric reference."

The biometric sample is presented for comparison with the biometric reference and seeks matches, in this case, between the photographs, returning an identifier for any matching reference. Naturally, the biometric reference in facial comparison will be the photo from the ID card, an official document that proclaims the ownership of an official personal identity.

Thus, it is worth noting that, i) when defining biometric data, Article 4.14 of the GDPR refers to data that "allows or confirms unique identification," ii) that Article 9, when qualifying biometric data as a special category of personal data, establishes as the only "condition" that they aim for the unique identification of a natural person, and iii) that the confirmation of the unique identification of an individual occurs in both identification and authentication scenarios, as also inferred from Recital 51 of the GDPR, which refers to photographs as a possibility of being biometric data, "are only included in the definition of biometric data when the fact that they are processed by specific technical means allows for the unique identification or authentication of a natural person."

Technically, the biometric template or facial vector extracted from the face of the ID card photograph against the facial vector extracted from the photograph requested from clients, which are matched against each other, is the evidence that a comparison is taking place.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

38/48

measurement that uniquely identifies each individual from whom biometric samples are taken.

Therefore, it must be concluded that the processing of biometric data constitutes the processing of special categories of data. This conclusion has been incorporated by the European Data Protection Board (EDPB) in its Guidelines 5/2022 on the use of facial recognition technology in law enforcement, and by the AEPD itself in the guide on presence control treatments using biometric systems mentioned by the responding party.

In this case, the screenshot of the application ***APPLICATION.1 provided by the claimant specifies the following information: "Check in by validating your identity and documentation," and in the mobile image, there is a space to upload a photo of the front of the ID, another photo of the back, and finally, a selfie for facial identification.

Furthermore, ***COMPANY.1 confirms in its response that, indeed, the ID was required along with the photograph for the purpose of biometric authentication: "(...) The most significant provider regarding the check-in process in the ***APPLICATION.1 app is ***COMPANY.2, which allows for the verification of the validity of the identity documents provided by the accommodated clients, the reading of the necessary data to fill in the traveler entry forms, as well as the biometric authentication of the same by checking via photo from their smartphones that the person registering is the same as the one providing the identity document (...)."

***COMPANY.1 describes the biometric authentication process in the following steps:

- 1) The image of the ID is captured
- 2) The image of the user (selfie) is captured

3) Biometric algorithms are applied to compare the degree of match between the ID image and the selfie.

4) A score is returned indicating the level of confidence that it is the same person.

5) No biometric pattern or similar is recorded, nor is any other type of biometric search or comparison performed. The images and data used in the biometric authentication are immediately and automatically deleted upon completion of the process.

Thus, biometric vectors are created in each of the images, subsequently comparing the one from the photo with that of the ID, achieving a verification of the client based on an official public document that certifies the identity of the person.

Although ***COMPANY.1 indicates that “once the biometric verification is completed, the process is validated for the person to continue with the check-in, and the two images are deleted,” the deletion of the photographs is not essential for the technical processing of the biometric feature of the face to have occurred, which constitutes the processing of personal data classified as special category data, aimed at identifying and verifying the client.

From the points noted in the previous sections, it can be concluded that, in the case analyzed in this initiation agreement for sanctioning proceedings, we are dealing with the processing of a special category of biometric personal data.

Article 9.1 of the GDPR, previously mentioned, when defining special categories of data, is based on the general principle of prohibition of their processing. The prohibition on processing special category data can only be lifted when one of the circumstances specified in paragraph 2 of Article 9 of the GDPR applies.

According to the information in the file and reflected in the background, ***COMPANY.1 did not consider that the personal data subject to processing constituted special categories of data and, therefore, did not determine the existence of any of the circumstances provided for in Article 9.2 of the GDPR for lifting the general prohibition on processing special categories of data and considered that the processing carried out does not affect this type of data.

In analyzing the application of these circumstances, it is important to remember that the CJEU has already ruled on the restrictive nature that must be granted to exceptions to the prohibition on processing special categories of data. For example, in its judgment of 4/07/2023, delivered in case C 252/21, it states the following:

76 On the other hand, insofar as it establishes an exception to the principle of prohibition of processing special categories of personal data, Article 9, paragraph 2, of the GDPR must be interpreted restrictively (see, in this regard, the judgments of September 17, 2014, *Baltic Agro*, C 3/13, EU:C:2014:2227, paragraph 24 and cited case law, and June 6, 2019, *Weil*, C 361/18, EU:C:2019:473, paragraph 43 and cited case law).

Taking the above into account and that the respondent has not specified the circumstance that it believes enables it to process the claimant's special category personal data, it must be understood that, without prejudice to what results from the instruction, it would not comply with what is dictated by Article 9.2 GDPR.

Therefore, in accordance with the evidence available at this time of the initiation agreement for sanctioning proceedings, it is considered that the known facts could constitute an infringement, attributable to ULPIA TRAJANA ALAMEDA, for violation of the previously transcribed article.

VIII

Classification of the infringement of Article 9 of the GDPR and qualification for the purposes of prescription

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

40/48

Article 83.5 of the GDPR classifies the violation of the following article as an administrative infringement, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the

total global annual turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the sole purpose of the statute of limitations, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and will be subject to a three-year statute of limitations, particularly the following:

e) The processing of personal data of the categories referred to in Article 9 of Regulation (EU) 2016/679, without any of the circumstances provided for in that provision and in Article 9 of this organic law."

IX

Proposal for Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and

j). In deciding to impose an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damage suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;

e) any previous infringement committed by the controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular, whether the controller or processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD provides:

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The ongoing nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

In the present case, considering the severity of the possible infringement, particularly regarding the consequences that its commission causes to the affected parties, the imposition of a fine, in addition to the adoption of measures, if appropriate, would be warranted.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepe@gob.es

42/48

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, with respect to the infringement committed by violating the provisions of Article 9 of the GDPR, allows for an initial administrative fine of 1,500.00 euros to be set.

X

Corrective Measures

If the infringement is confirmed, the resolution issued may establish the corrective measures that the infringing entity must adopt to put an end to the non-compliance with personal data protection legislation, in this case, Article 5.1.c) of the GDPR, in accordance with the provisions of the aforementioned Article 58.2.d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified time frame...”

Thus, the responsible entity may be required to adjust its actions to the personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this act, the alleged infringement committed and the facts that could lead to this possible violation of data protection regulations are established, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

However, in this case, regardless of the above, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, the resolution adopted may require ULPIA to, within 3 months from the date of effectiveness of the resolution concluding this procedure:

- Adopt the necessary measures to avoid requiring guests to provide a copy of their identity document and their image to be accommodated.
- Cease activities involving the processing of biometric data or comply with the requirements set forth in the GDPR, including conducting and passing a Data Protection Impact Assessment (DPIA).

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

43/48

It is warned that failure to comply with the possible order to adopt measures imposed by this agency in the resolution of the present sanctioning procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the opening of a further administrative sanctioning procedure.

It is also reminded that neither the acknowledgment of the infringement committed nor, where applicable, the voluntary payment of the proposed amounts, exempts the obligation to adopt the necessary measures to cease the conduct or correct the effects of the infringement committed and to demonstrate compliance with this obligation before this AEPD.

Therefore, in light of the above, by the Presidency of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against ULPIA TRAJANA ALAMEDA S.L., with NIF B90468273, for the alleged infringement of Articles 5.1.c) and 9 of the GDPR, classified in Article 83.5 of the GDPR.

SECOND: TO APPOINT B.B.B. as the instructor and C.C.C. as the secretary, indicating that they may be recused, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the file, for evidentiary purposes, the complaint filed by the complainant and its documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be an administrative fine of 1,000.00 euros for the infringement of Article 5.1.c) of the GDPR and 1,500.00 euros for the infringement of Article 9 of the GDPR, without prejudice to what results from the instruction.

The sum of these amounts yields a total of 2,500 euros.

FIFTH: TO NOTIFY this agreement to ULPIA TRAJANA ALAMEDA S.L., with NIF B90468273, granting a hearing period of ten working days for it to submit allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the procedure number that appears in the heading of this document.

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a 20% reduction of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeprd.gob.es

44/48

sanction that may be imposed in the present procedure. With the application of this reduction, the sanction would be established at 2,000.00 euros, resolving the procedure with the imposition of this sanction.

Likewise, at any time prior to the resolution of this procedure, the voluntary payment of the proposed sanction may be made, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be established at 2,000.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations regarding the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were applicable, the amount of the sanction would be

established at 1,500.00 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the express withdrawal or renunciation of any action or administrative appeal against the sanction.

For these purposes, in the event of opting for any of them, a communication must be sent to the General Subdirectorate of Data Inspection indicating which of the two reductions is being opted for or if it is for both.

In the event that you choose to proceed with the voluntary payment of any of the amounts indicated above (2,000.00 euros or 1,500.00 euros), you must make it effective by depositing it into account No. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering. Likewise, you must send the proof of payment to the General Subdirectorate of Inspection.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, no administrative appeal can be filed against this act.

1479-111224

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

>>

SECOND: On April 15, 2025, ULPIA proceeded to pay the sanction in the amount of 1,500.00 euros, making use of the two reductions provided for in the previously transcribed initiation agreement, which implies the acknowledgment of responsibility regarding the facts referred to in the initiation agreement and its legal qualification.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

45/48

THIRD: The initiation agreement transcribed above stated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the initiation agreement is appropriate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures"

provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely pecuniary or when a pecuniary sanction and another non-pecuniary sanction can be imposed but the impropriety of the latter has been justified, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

46/48

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative pathway against the sanction. The percentage of reduction provided in this section may be increased by regulation.

III

Voluntary Payment and Acknowledgment of Responsibility

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified initiation agreement informed about the possibility of acknowledging responsibility and making a voluntary payment of the proposed sanction, which would entail two cumulative reductions of 20% each. With the application of these two reductions, the sanction would be established at €1,500.00, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

After the notification of the aforementioned initiation agreement, ULPIA has proceeded to acknowledge responsibility and make a voluntary payment of the sanction, availing itself of the two reductions provided. In accordance with section 3 of Article 85 LPACAP, the effectiveness of the aforementioned reductions shall be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative pathway against the sanction.

It should be noted that, according to the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure shall decide all matters raised by the interested parties and any other issues arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the initiation agreement transcribed in this resolution.

The sum of the aforementioned amounts yields a total of €2,500.00.

After ULPIA TRAJANA ALAMEDA S.L. has made the prompt payment and acknowledged responsibility, a reduction of 40% of the aforementioned total is applied, which results in a final amount of €1,500.00.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

47/48

The effectiveness of the aforementioned reductions is, in any case, conditioned upon the withdrawal or

renunciation of any action or appeal in the administrative pathway.

SECOND: TO DECLARE the termination of procedure EXP202311801, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO ORDER ULPIA TRAJANA ALAMEDA S.L. to notify the Agency of the adoption of the measures described in the legal grounds of the initiation agreement transcribed in this resolution within 3 months from the date this resolution becomes final and enforceable.

FOURTH: TO NOTIFY this resolution to ULPIA TRAJANA ALAMEDA S.L.

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment and acknowledgment of responsibility to the withdrawal or renunciation of any action or appeal in the administrative pathway, this resolution shall be final in the administrative pathway and fully enforceable from its notification.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative pathway as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

However, in accordance with the provisions of Article 90.3.a) of the LPACAP, the final resolution in the administrative pathway may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry

[<https://sedeaepd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

1259-260325

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es

48/48

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es